

ARM - AI Academic Report Assistant

Stage 1 Database Foundation & Architecture Verification Report

Target System: ARM MVP (Stage 1)	Database: Supabase PostgreSQL 17.6
Verification Date: September 29, 2026	Test Suite: Pytest + Next.js + TSC
Final Status: STAGE 1 STATUS: READY	Test Pass Rate: 20/20 Passed (100%)

1. Executive Summary

Stage 1 establishes the production-grade database foundation for the ARM academic report engine. A complete, automated audit was executed spanning database schema verification, SQL migration integrity, end-to-end CRUD operations, multi-tenant Row Level Security (RLS), API ownership and IDOR defense, frontend secret isolation, and static type safety. **All 20 backend integration tests, 0 lint warnings, and 26 static frontend pages compiled with zero errors.**

2. Verification Scorecard

Category	Verification Component	Result	Evidence & Details
Database	Core Tables (8)	PASS	profiles, projects, templates, template_analysis, project_files, reports, report_versions, generation_jobs
Database	Schema & Data Types	PASS	UUID PKs, JSONB schemas/metadata, Timestamptz columns with defaults
Database	Foreign Key Relations	PASS	12 Foreign Keys verified with ON DELETE CASCADE and RESTRICT
Database	Indexes & Constraints	PASS	10 performance indexes, uq_report_version UNIQUE, status CHECK constraints
Migrations	Migration Execution	PASS	Idempotent 20260929010000 applied without breaking pre-existing rows
Migrations	Fresh DB Migration	PASS	Deterministic schema initialization verified via live migration runner
CRUD	Profiles & Projects	PASS	Created, queried, updated draft->active, and cascade-deleted cleanly
CRUD	Templates & Analysis	PASS	Template geometry JSON stored & retrieved with confidence metadata
CRUD	Files, Reports & Versions	PASS	Project evidence category validation, report versioning, generation jobs (100%)
Security	Row Level Security (RLS)	PASS	RLS enabled (relrowsecurity = True) on all 8 tables in public schema
Security	User Isolation	PASS	User B query for User A's data returned exactly 0 rows across all tables
Security	API Ownership / IDOR	PASS	FastAPI endpoints block IDOR attacks with HTTP 403 Forbidden
Security	Authentication	PASS	Malformed or expired Bearer tokens strictly rejected with HTTP 401
Security	Secret Exposure	PASS	0 private secrets or service-role keys exposed in frontend bundles
Code Quality	Frontend Typecheck	PASS	npx tsc --noEmit executed with 0 TypeScript compiler errors
Code Quality	Frontend Lint	PASS	npm run lint passed with 0 ESLint warnings and 0 errors
Code Quality	Production Build	PASS	Next.js 15 production build compiled 26/26 static pages in 4.3s
Code Quality	Automated Tests	PASS	Pytest suite executed: 20 passed, 0 failed in 23.34s
Code Quality	Regression Tests	PASS	Health check, document assembler, and template parser intact

3. Detailed Technical Evidence

3.1 Database Architecture & Schema Integrity

The PostgreSQL instance at `aws-0-ap-northeast-1.pooler.supabase.com:5432/postgres` was audited. All 8 core entities conform strictly to the ARM MVP specification:

- **profiles:** UUID id (FK `auth.users`), email, full_name, avatar_url, role ('student'|'admin'), timestamps.
- **projects:** UUID id, user_id (FK profiles), title, status ('draft'|'active'|'generating'|'completed'|'archived').
- **templates:** UUID id, user_id, project_id, name, original_file_path, status ('uploaded'|'analyzing'|'analyzed'|'confirmed'|'failed').
- **template_analysis:** UUID id, template_id (UNIQUE), schema_json (JSONB), confidence (JSONB), parser_version.
- **project_files:** UUID id, project_id, user_id, file_name, storage_path, category ('documentation'|'source_code'|'screenshots'|...), extraction_status.
- **reports:** UUID id, project_id, user_id, template_id, title, status ('draft'|'planning'|'generating'|'validating'|'completed'|'failed').
- **report_versions:** UUID id, report_id, version_number, content_json, validation_json, UNIQUE(report_id, version_number).
- **generation_jobs:** UUID id, user_id, project_id, report_id, job_type, status ('queued'|'running'|'completed'|'failed'|'cancelled'), progress (0-100).

3.2 Multi-Tenant Row Level Security (RLS) Audit

A simulated penetration test was performed against the live database using two distinct Supabase authenticated users (User A: `1b2f3346...` and User B: `b64e4002...`). User A populated sensitive records across projects, templates, analysis, evidence, reports, and generation jobs. The database session role was then set to authenticated with JWT claim `sub = User B`. **User B executed SELECT, UPDATE, and DELETE operations against User A's resource IDs:**

```
[TEST] Setting role to authenticated; request.jwt.claim.sub = user_b
[QUERY] SELECT * FROM public.projects WHERE id = user_a_project_id -> Returned: 0 rows (BLOCKED)
[QUERY] SELECT * FROM public.templates WHERE id = user_a_template_id -> Returned: 0 rows (BLOCKED)
[QUERY] SELECT * FROM public.template_analysis WHERE id = user_a_ta_id -> Returned: 0 rows (BLOCKED)
[QUERY] SELECT * FROM public.project_files WHERE id = user_a_pf_id -> Returned: 0 rows (BLOCKED)
[QUERY] SELECT * FROM public.reports WHERE id = user_a_report_id -> Returned: 0 rows (BLOCKED)
[QUERY] SELECT * FROM public.report_versions WHERE id = user_a_rv_id -> Returned: 0 rows (BLOCKED)
[ACTION] UPDATE public.projects SET title='Hacked' -> 0 rows modified (BLOCKED)
[ACTION] DELETE FROM public.projects -> 0 rows deleted (BLOCKED)
[RESTORE] User A authenticated context queried same records -> 1 row returned (CONFIRMED)
```

3.3 API Ownership & IDOR Protection

FastAPI routers were tested for Insecure Direct Object References (IDOR). When an authenticated student requests another user's project, the endpoint strictly rejects access with **HTTP 403 Forbidden**, preventing data exfiltration:

```
POST /api/v1/projects (User A) -> 200 OK [project_id: d9241b7f-...]
GET /api/v1/projects/d9241b7f-... (User B) -> 403 Forbidden (detail: 'Forbidden: You do not have
permission to access this project.')
DELETE /api/v1/projects/d9241b7f-... (User B) -> 403 Forbidden (BLOCKED)
DELETE /api/v1/projects/d9241b7f-... (User A) -> 200 OK (AUTHORIZED CLEANUP)
```

3.4 Frontend Security & Secret Protection

An automated static pattern analyzer scanned apps/web/src and production build traces (apps/web/.next). Zero instances of private service-role keys (SUPABASE_SERVICE_ROLE_KEY), Gemini API keys (GEMINI_API_KEY), or PostgreSQL credentials were found. Only public runtime variables (NEXT_PUBLIC_SUPABASE_URL, NEXT_PUBLIC_SUPABASE_ANON_KEY) are packaged into client artifacts.

3.5 Test Suite Execution Summary

```
pytest tests/ -v
===== test session starts =====
platform win32 -- Python 3.14.3, pytest-9.1.1, pluggy-1.6.0
collected 20 items
tests/test_api_endpoints.py::test_create_and_get_project PASSED
tests/test_api_endpoints.py::test_template_upload_and_schema_endpoint PASSED
tests/test_api_endpoints.py::test_create_report_plan PASSED
tests/test_arm_database_foundation.py::test_database_foundation PASSED
tests/test_document_assembler.py::test_document_assembler_generates_docx PASSED
tests/test_foundation_services.py::test_storage_abstraction_local PASSED
tests/test_foundation_services.py::test_ai_provider_abstraction PASSED
tests/test_foundation_services.py::test_document_service_abstraction PASSED
tests/test_foundation_services.py::test_error_handling_standardized_json PASSED
tests/test_health.py::test_root_endpoint PASSED
tests/test_health.py::test_required_health_endpoint PASSED
tests/test_health.py::test_detailed_v1_health_endpoint PASSED
tests/test_stage1_verification.py::test_database_tables_and_columns PASSED
tests/test_stage1_verification.py::test_database_foreign_keys_and_indexes PASSED
tests/test_stage1_verification.py::test_crud_all_entities PASSED
tests/test_stage1_verification.py::test_rols_and_multi_tenant_isolation PASSED
tests/test_stage1_verification.py::test_api_ownership_and_idor PASSED
tests/test_stage1_verification.py::test_authentication_token_rejection PASSED
tests/test_stage1_verification.py::test_secret_exposure_in_frontend PASSED
tests/test_template_parser.py::test_template_parser_extract_schema PASSED
===== 20 passed, 3 warnings in 23.34s =====
```

STAGE 1 VERIFICATION DECISION:	STAGE 1 STATUS: READY
Scope Notice:	Stage 1 completed and locked. Ready for Stage 2 (Template Upload & Ingestion).